

# IA 642 Defensive Security

## Week 05 Module 01 Lab 5.1

Mapping Meridian's Campaign in ATT&CK Navigator and STIX

Cyber Threat Intelligence · MITRE ATT&CK Enterprise v19 · STIX 2.1

Repository: [github.com/unaishhazan/ia642-week05-lab51-cti](https://github.com/unaishhazan/ia642-week05-lab51-cti)

|                      |                           |             |              |
|----------------------|---------------------------|-------------|--------------|
| <b>Group members</b> | Unais Ali                 | <b>EID</b>  | E02805019    |
|                      | Hafiz Usama               |             | E02574092    |
| <b>Course</b>        | IA 642 Defensive Security | <b>Week</b> | 05, Lab 5.1  |
| <b>Tools</b>         | Navigator 5.3.2, STIX 2.1 | <b>Date</b> | October 2026 |

### Lab overview

This lab maps Meridian's evidence cards (E1–E4) onto MITRE ATT&CK Enterprise v19 in ATT&CK Navigator, tests lecture beacon mappings against ATT&CK wording, compares the Meridian layer to FIN7 (G0046), writes a three-object STIX 2.1 bundle, validates with the starter-kit checkers, and argues whether the intrusion looks opportunistic or targeted. Submitted files: this PDF, `meridian_layer.json`, `meridian_overlap_layer.json`, and `meridian_stix.json`.

| Deliverable                              | Checker / note                                                   |
|------------------------------------------|------------------------------------------------------------------|
| <code>meridian_layer.json</code>         | <code>check_layer.py</code> prints OK (7 techniques)             |
| <code>meridian_overlap_layer.json</code> | <code>check_layer.py --overlap</code> (overlap fraction 1 of 67) |
| <code>meridian_stix.json</code>          | <code>check_stix.py</code> RESULT: ALL CHECKS PASSED             |
| This report                              | Q1–Q6, CAPTURE #1–#4, FIN7 profile, Challenge                    |

### Task 1. Setup

Python 3.11.9 virtual environment in `lab51/`, with pinned packages from `requirements.txt` (`stix2-validator` 3.2.0, `stix2` 3.0.2). Running `check_stix.py` on the skeleton produced the expected failures before editing `meridian_stix.json`, confirming the checker works.

### Part A. Navigator layer (Tasks 2–6)

#### Q1. ATT&CK version and T1027 tactic column

The layer uses MITRE ATT&CK Enterprise v19 (Navigator 5.3.2, layer format 4.5). In v19, T1027 Obfuscated Files or Information appears under the **Stealth** tactic column (TA0005). Week 05 materials note that v19 renamed the former Defense Evasion column to Stealth and added Defense Impairment (TA0112). T1027 was scored in Stealth to match the Navigator matrix.

#### Anchored techniques (Tasks 2–3)

| Technique               | Tactic            | Score | Evidence basis                                             |
|-------------------------|-------------------|-------|------------------------------------------------------------|
| T1558.003 Kerberoasting | Credential Access | 95    | E2: nine 4769 RC4 (0x17) for one SPN                       |
| T1027 Obfuscated Files  | Stealth           | 45    | E3 stand-in structure (not <code>svcupdate_v2.bin</code> ) |

**T1558.003 comment used.** E2: nine Event ID 4769 requests for one SPN (`MSSQLSvc/sqlapp01...`), RC4 (0x17), about 3.5 minutes, from an ordinary logged-in account; ticket cracked offline. Matches ATT&CK Kerberoasting.

**T1027 comment used.** E3 stand-in shows MZ marker, MeridianLoader banner, decode-stub-shaped bytes

(90 90 90 31 C0...), and embedded C2 host. Fits Obfuscated Files parent, but the artifact is a defanged stand-in, so confidence stays possible/contested.

## Q2. Parent vs sub-technique for T1027

I scored the parent T1027, not a sub-technique such as T1027.002 Software Packing. The deciding E3 facts are the decode-stub-shaped byte sequence and embedded strings inside a non-valid PE stand-in. That shows obfuscated/encoded content without proving a specific packing method. I did not score higher because the file is an IR-defanged stand-in with no working code; citing `svcupdate_v2.bin` would be wrong because that was a YARA test file I built, not adversary evidence.

## Q3. Task 4 beacon mappings (E1)

| Candidate                   | Decision | Score | Reason (ATT&CK wording + E1)                                   |
|-----------------------------|----------|-------|----------------------------------------------------------------|
| T1071.001 Web Protocols     | Include  | 75    | Application-layer C2 over web ports; 143 TLS sessions to :443  |
| T1573.002 Asymmetric Crypto | Reject   | 0     | Ordinary TLS is inherent protocol protection, not added crypto |
| T1029 Scheduled Transfer    | Reject   | 0     | Timer is C2 check-in, not scheduled data exfiltration          |
| T1036.005 (optional)        | Include  | 40    | <code>svcupdate.bin</code> / MeridianLoader naming (E3)        |

**T1071.001.** ATT&CK describes adversaries who “communicate using application layer protocols to avoid detection/network filtering by blending in with existing traffic.” E1 shows 143 outbound TLS sessions to `sync-update.meridian-relay.test` on TCP 443 with about an 8-minute cadence. Without a packet capture, the HTTP (or other) payload inside TLS cannot be confirmed, so the score is strong but not 90+.

**T1573.002.** ATT&CK requires asymmetric encryption “to conceal command and control traffic rather than relying on any inherent protections provided by a communication protocol.” E1 is ordinary TLS 1.2 with a publicly trusted certificate. That is inherent protocol protection. Parent T1573 is not a better fit for the same reason.

**T1029.** ATT&CK Scheduled Transfer is about scheduling *data exfiltration*. E1’s timer shows C2 check-ins (about 540–610 B send / 1.2–1.4 KB receive), not evidence that Meridian data left on a schedule.

## Q4. Task 5: T1110.001 Password Guessing (E4)

No. I scored T1110.001 at 0 for this campaign. Two deciding E4 facts: (1) alerts are on `vpn-gw-01` and `corp-backup-01`, not `BILL-WS-14` or `MERIDIAN-DC01`; (2) no time, account, or address link to E1–E3, and `corp-backup-01`’s success matches a known nightly password-change re-auth. Evidence that would change the answer: the same source IP or username appearing in E2’s 4769 events, or a successful login on `BILL-WS-14` / `DC01` tied to the VPN failures.

## CAPTURE #1: finished layer and check\_layer.py

**CAPTURE #1.** Finished Meridian layer in ATT&CK Navigator (show IDs on), plus full `check_layer.py` output ending in OK.

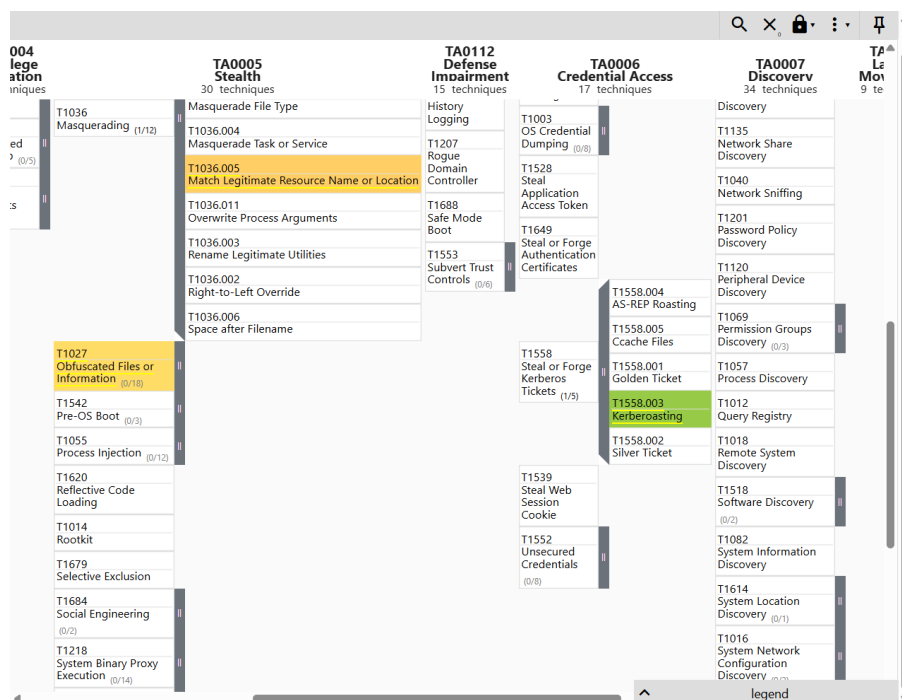


Figure 1: CAPTURE #1: Finished Meridian layer in ATT&CK Navigator 5.3.2 (show IDs on). T1558.003 Kerberoasting scored high (green). Companion board below lists every annotated technique.

### CAPTURE #1 - Meridian Layer (ATT&CK Enterprise v19)

Layer: Meridian - Lab 5.1 - Unais Ali and Hafiz Usama | Navigator 5.3.2 | show IDs on

| Technique ID     | Name                              | Tactic              | Score     |
|------------------|-----------------------------------|---------------------|-----------|
| <b>T1558.003</b> | Kerberoasting                     | Credential Access   | <b>95</b> |
| <b>T1071.001</b> | Web Protocols                     | Command and Control | <b>75</b> |
| <b>T1027</b>     | Obfuscated Files or Information   | Stealth             | <b>45</b> |
| <b>T1036.005</b> | Match Legitimate Name or Location | Stealth             | <b>40</b> |
| <b>T1573.002</b> | Asymmetric Cryptography (REJECT)  | Command and Control | <b>0</b>  |
| <b>T1029</b>     | Scheduled Transfer (REJECT)       | Exfiltration        | <b>0</b>  |
| <b>T1110.001</b> | Password Guessing (REJECT)        | Credential Access   | <b>0</b>  |

Green = strong include | Yellow = possible/contested | Red = rejected (score 0).

Figure 2: CAPTURE #1 companion: full technique ID, name, tactic, and score list for all seven annotated techniques.

| Layer: 'Meridian Lab 5.1 - Ali & Usama'                               |       |         |                     |
|-----------------------------------------------------------------------|-------|---------|---------------------|
| domain: enterprise-attack ATT&CK v19 Navigator 5.3.2 layer format 4.5 |       |         |                     |
| Technique                                                             | Score | Comment | Tactic(s)           |
| T1027                                                                 | 45    | yes     | stealth             |
| T1029                                                                 | 0     | yes     | exfiltration        |
| T1036.005                                                             | 40    | yes     | stealth             |
| T1071.001                                                             | 75    | yes     | command-and-control |

|           |    |     |                     |
|-----------|----|-----|---------------------|
| T1110.001 | 0  | yes | credential-access   |
| T1558.003 | 95 | yes | credential-access   |
| T1573.002 | 0  | yes | command-and-control |

7 technique(s) annotated.

OK -- every technique has a score and a comment.

## Part B. FIN7 comparison (Task 7)

I compared Meridian against FIN7 (G0046). When FIN7 was selected in Navigator, the technique-count badge showed **67** (ATT&CK v19). Overlap expression:  $a > 0$  and  $b > 0$ . Exact-ID overlap is only T1558.003.

**CAPTURE #2.** Overlap tab in ATT&CK Navigator and full `check_layer.py --overlap` output.

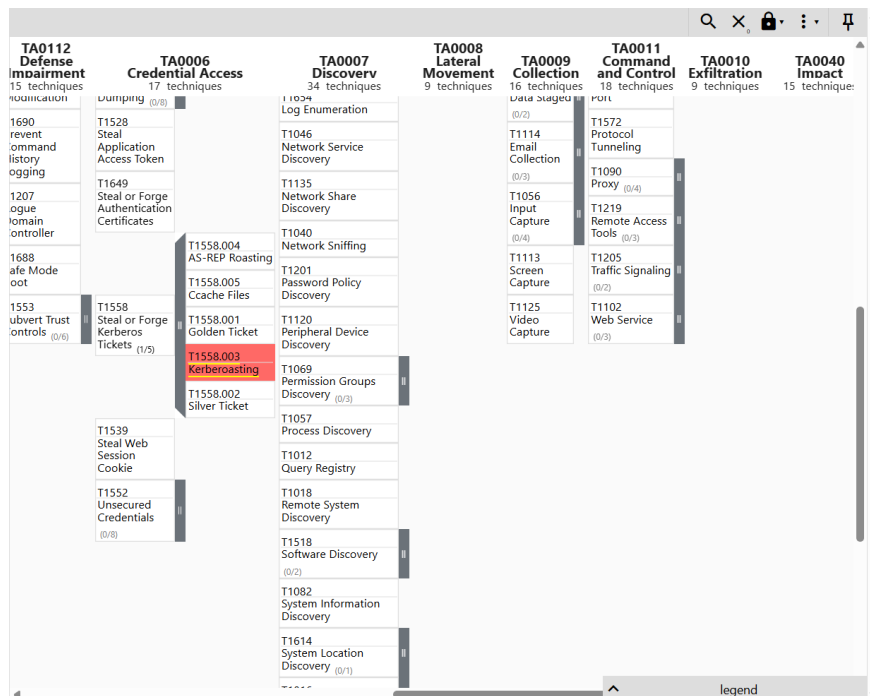


Figure 3: CAPTURE #2: Meridian and FIN7 (G0046) overlap tab. Exact-ID match T1558.003 Kerberoasting highlighted (score 1, red on default scale).

## CAPTURE #2 - Meridian and FIN7 (G0046) Overlap

Expression:  $a > 0$  and  $b > 0$  | FIN7 group total = 67 (ATT&CK v19)

**Exact-ID overlap (score 1)**

**T1558.003 Kerberoasting**

Overlap fraction = 1 of 67

Near-misses: Meridian T1027 vs FIN7 T1027.010 / T1027.016; Meridian T1071.001 vs FIN7 T1071.004

Authors: Unais Ali and Hafiz Usama

Figure 4: CAPTURE #2 companion: overlap fraction = 1 of 67 (FIN7 group total).

```
Layer: 'Meridian and FIN7 (G0046) overlap'
domain: enterprise-attack ATT&CK v19 Navigator 5.3.2 layer format 4.5

Techniques in BOTH layers (score 1): 1
  T1558.003 credential-access

Techniques scored in either layer: 1
Report the overlap as a fraction of your GROUP layer's total
(the count shown next to X when you selected the group).
```

**Overlap fraction: 1 of 67.**

**Near-misses** (exact-ID tool miss): Meridian parent T1027 vs FIN7's T1027.010 / T1027.016; Meridian T1071.001 Web Protocols vs FIN7's T1071.004 DNS.

### Adversary profile

FIN7 (G0046) is a financially motivated enterprise intrusion group documented across retail, hospitality, and broader industries, with later big-game-hunting activity. Two documented procedures that relate to Meridian's evidence, both recorded on the FIN7 **group page** (not a campaign page): (1) T1558.003 Kerberoasting, which is an exact-ID match to Meridian E2; (2) T1071.004 DNS (Application Layer Protocol), which is the same tactic family as Meridian's scored T1071.001 Web Protocols but a different sub-technique, so it is a near-miss rather than an exact overlap. Meridian's exact-ID overlap with FIN7 is 1 of 67 (only T1558.003). That small fraction shows shared tradecraft, not identity. Meridian's evidence does **not** support attributing the intrusion to FIN7: there is no FIN7-specific malware family, no confirmed POS/ransomware payload, and no unique infrastructure overlap beyond a documentation-only `.test` host and RFC 5737 address used in the course lab.

### Q5. Why might a 119-technique group overlap more without being likelier?

A group with 119 documented techniques (for example APT29) covers more of the ATT&CK matrix, so random or common techniques in a small Meridian layer are more likely to collide by chance. Overlap count is not a likelihood score: denser public reporting inflates matches without proving that group operated at Meridian. Attribution still needs unique malware, infrastructure, or procedure-level detail, and an honest statement of what the evidence cannot support.

## Part C. STIX 2.1 bundle (Tasks 8–10)

Option A (file IOC): Indicator pattern uses the E3 SHA-256 of the `svcupdate.bin` stand-in.

Attack-Pattern is T1027 Obfuscated Files or Information (score  $45 \geq 30$ ; not the lecture's T1558.003).

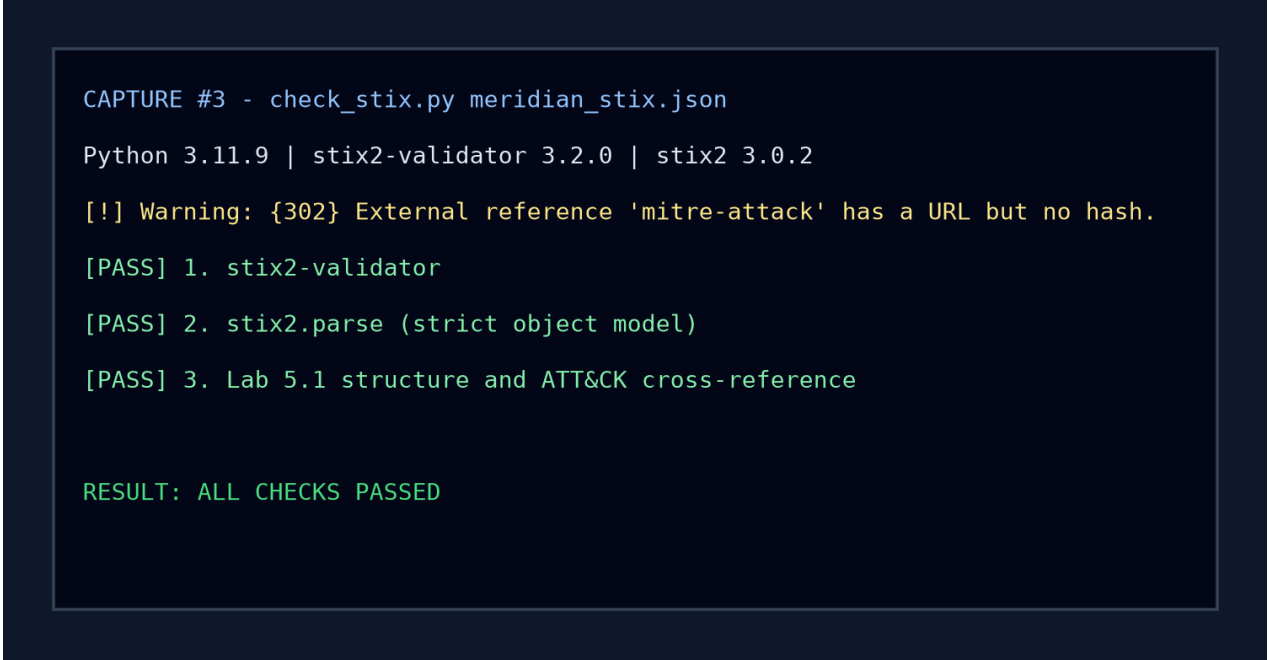
Relationship: `indicator --indicates--> attack-pattern`.

```
pattern: [file:hashes.'SHA-256' = '3f77970a8c10f1af034e984b3b06f76db1708d377e8c3f9085af95823c9e2d73']
attack-pattern external_id: T1027
url: https://attack.mitre.org/techniques/T1027/
source_name: mitre-attack
```

**CAPTURE #3.** Complete `check_stix.py` output ending in `RESULT: ALL CHECKS PASSED` ({302} warning ignored).

```
Python 3.11.9 | stix2-validator 3.2.0 | stix2 3.0.2
[!] Warning: {302} External reference 'mitre-attack' has a URL but no hash.
[PASS] 1. stix2-validator
[PASS] 2. stix2.parse (strict object model)
[PASS] 3. Lab 5.1 structure and ATT&CK cross-reference

RESULT: ALL CHECKS PASSED
```



```
CAPTURE #3 - check_stix.py meridian_stix.json

Python 3.11.9 | stix2-validator 3.2.0 | stix2 3.0.2

[!] Warning: {302} External reference 'mitre-attack' has a URL but no hash.

[PASS] 1. stix2-validator
[PASS] 2. stix2.parse (strict object model)
[PASS] 3. Lab 5.1 structure and ATT&CK cross-reference

RESULT: ALL CHECKS PASSED
```

Figure 5: CAPTURE #3: STIX checker summary figure.

## CAPTURE #4 and Q6: visualization

**CAPTURE #4.** OASIS STIX Visualizer graph for `meridian_stix.json`: 2 nodes, 1 edge labeled indicates.

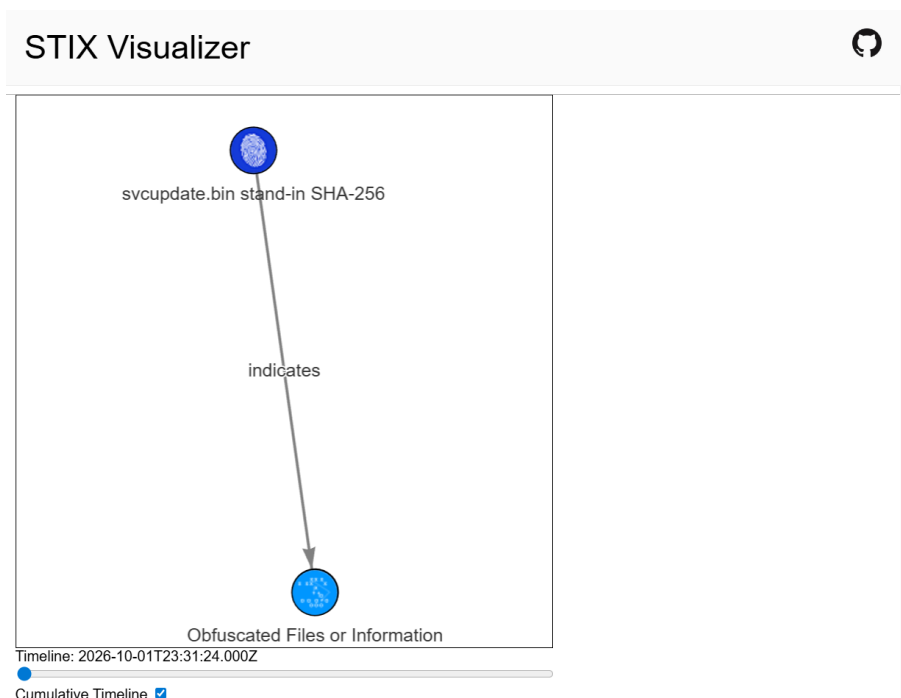


Figure 6: CAPTURE #4: OASIS STIX Visualizer. Indicator `svcupdate.bin` stand-in SHA-256 indicates Attack-Pattern Obfuscated Files or Information (T1027).

**Q6.** The graph shows **2 nodes** and **1 edge**. The edge label is **indicates**. The Relationship object appears as an edge because STIX visualizers render SROs (STIX Relationship Objects) as links between SDOs (STIX Domain Objects). Indicator and Attack-Pattern are domain objects (nodes); the **indicates** relationship is an SRO, so the tool draws it as the connecting edge rather than as a third node. Do not use the timeline slider when checking properties: it can hide objects by timestamp.

### Challenge. Opportunistic or targeted?

**Position:** Meridian's intrusion looks more like a *targeted* campaign against Meridian than a purely opportunistic smash-and-grab, but the case is not closed.

Two scored techniques support a Meridian-focused operator. T1558.003 (score 95) shows Kerberoasting aimed at `svc-billingsql`'s MSSQL SPN on the Meridian domain. That is a purposeful credential attack against a named billing/SQL service, not a random internet scan. T1071.001 (score 75) shows long-lived TLS beaconing from BILL-WS-14 to a Meridian-themed relay host (`sync-update.meridian-relay.test`) with a host-unique JA3. That combination of a Meridian service-account target and Meridian-branded C2 naming is hard to square with an actor who only stumbled onto an open port.

A targeting-relevant Evidence Card fact is E3's embedded strings: `MeridianLoader/2.1` and `sync-update.meridian-relay.test` inside the stand-in recovered from BILL-WS-14. That is Meridian-specific branding in the loader/C2 path. From Task 7, the FIN7 overlap is only **1 of 67** exact technique IDs, which warns against treating a famous group label as proof of identity even when Kerberoasting overlaps.

What would strengthen targeting: packet capture of the TLS sessions showing Meridian data theft, or evidence that `svc-billingsql` access led to billing records. What would overturn targeting toward opportunistic: discovery that many unrelated orgs hit the same loader hash/JA3 with generic naming, or proof the `.test` host was only a shared commodity C2 with no Meridian focus. Until then, I read the campaign as Meridian-directed tradecraft with incomplete attribution.

## References

- MITRE ATT&CK Enterprise Matrix (v19): <https://attack.mitre.org/>
- MITRE ATT&CK Navigator 5.3.2: <https://mitre-attack.github.io/attack-navigator/>
- OASIS, STIX Version 2.1 (2021)
- OASIS STIX Visualizer: <https://oasis-open.github.io/cti-stix-visualization/>
- Bianco, D. J. (2013). The Pyramid of Pain.
- Althouse, J., Atkinson, J., & Atkins, J. (2017). JA3: a method for profiling SSL/TLS clients.